

PENETRATION TESTING TECHNICAL REPORT

Target Environment

Forgotten Portal – DockerLabs Lab Environment

Classification	CONFIDENTIAL
Report Date	March 23, 2026
Prepared By	Valentina Ramírez
Organization	EAFIT University
Methodology	PTES (Penetration Testing Execution Standard)
Overall Risk	CRITICAL

This document contains confidential security information. Distribution is restricted to authorized personnel only.

Table of Contents

1. Executive Summary	3
2. Engagement Overview	4
2.1 Scope	4
2.2 Objectives	4
2.3 Methodology: PTES	4
2.4 Tools Used	5
3. Findings Summary	6
4. Detailed Findings	7
FINDING-01 – Sensitive Information Disclosure via HTML Source Code Comments	7
FINDING-02 – Unrestricted PHP File Upload Enabling Remote Code Execution (RCE)	7
FINDING-03 – Directory Listing Enabled on the /uploads Directory	8
FINDING-04 – User Credentials Stored in Base64 within a Publicly Readable Log File	9
FINDING-05 – Shared SSH RSA Private Key Deployed Across All System Users	10
FINDING-06 – SSH Key Passphrase Disclosed in Plaintext within an Internal Incident Report	10
FINDING-07 – Unrestricted Sudo Privileges on tar Binary Enabling Privilege Escalation to Root	11
5. MITRE ATT&CK Mapping	13
6. Risk Matrix (ISO/IEC 27005)	15
7. Recommendations Summary	16
7.1 Web Server Hardening	16
7.2 Operating System Hardening	16
7.3 SOC / Monitoring Considerations	17
8. Appendices	18
Appendix A – Engagement Environment	18
Appendix B – Acronyms	18
Appendix C – Disclaimer	18

1. Executive Summary

This report documents the results of a penetration test conducted on the Forgotten Portal lab environment (DockerLabs), performed by Valentina Ramírez on March 23, 2026. The assessment followed the Penetration Testing Execution Standard (PTES) methodology, encompassing reconnaissance, enumeration, exploitation, and post-exploitation phases.

The target system, a Docker container running an Ubuntu Linux server with an Apache web application and SSH service exposed on IP address 172.17.0.2, was fully compromised during this engagement. The assessment identified seven security findings across Critical, High, and Medium severity ratings. The tester achieved complete system compromise — including unauthenticated remote code execution, lateral movement across three user accounts, and escalation to root privileges — through the chained exploitation of multiple vulnerabilities.

The overall risk posture of the environment is rated CRITICAL. The primary attack chain proceeded as follows: an unauthenticated PHP file upload (FINDING-02) provided initial remote code execution; credential exposure in a server log file (FINDING-04) enabled lateral movement to a user account; a shared SSH private key combined with an exposed passphrase (FINDING-05, FINDING-06) allowed further lateral movement; and an unrestricted sudo configuration on the tar binary (FINDING-07) enabled full privilege escalation to root. No advanced techniques or zero-day vulnerabilities were required; all findings exploit well-known misconfiguration patterns.

According to the IBM Cost of a Data Breach Report 2024, the global average cost of a data breach is \$4.88 million USD, with an average time to identify and contain a breach of 258 days. Prompt remediation of the findings documented in this report — particularly the four Critical-severity findings — is strongly recommended.

Overall Risk	Findings	Systems Tested	Engagement Date
CRITICAL	7 Total (3 Critical, 2 High, 2 Medium)	1 Docker Container (172.17.0.2)	March 23, 2026

2. Engagement Overview

2.1 Scope

The scope of this engagement was strictly limited to the Forgotten Portal Docker container deployed via the DockerLabs platform. The target operated on a private Docker network with the following services in scope:

Port	Protocol	Service	Version
22	TCP	SSH	OpenSSH 9.6p1 Ubuntu 3ubuntu13.5
80	TCP	HTTP	Apache httpd 2.4.58 (Ubuntu)

All 65,535 TCP ports were scanned. No other ports were found to be open. No systems, networks, or services external to the Docker container were included in scope.

2.2 Objectives

- Identify all exposed services and open ports on the target system.
- Detect and enumerate vulnerabilities through reconnaissance and analysis techniques.
- Obtain unauthorized access to the system through controlled exploitation.
- Escalate privileges to the highest available level (root).
- Document all findings with supporting technical evidence.

2.3 Methodology: PTES

This assessment followed the Penetration Testing Execution Standard (PTES), a globally recognized framework for conducting structured penetration tests. The methodology was applied across six sequential phases:

Phase	Name	Activities Performed
1	Preparation	Defined scope, objectives, tools, and environment configuration. Deployed the target container using the DockerLabs auto-deploy script.
2	Exploration	Host discovery via ping (TTL=64 confirmed Linux OS). Initial port reconnaissance.
3	Analysis	Full-port Nmap scan; web application inspection via browser DevTools; JavaScript analysis; Gobuster directory enumeration; robots.txt verification.
4	Attack	Crafted and uploaded PHP web shell; established reverse shell; confirmed RCE as www-data.

5	Deep Access	Internal host enumeration; credential extraction from access_log; lateral movement via su to alice; SSH lateral movement to bob via shared RSA key; privilege escalation to root via tar sudo.
6	Documentation	Simultaneous documentation of all findings with screenshot evidence and technical analysis. Preparation of this report.

2.4 Tools Used

Tool	Purpose
Nmap 7.95	Full TCP port scan; service/version detection; NSE script execution
Gobuster 3.8	Web directory and path enumeration using directory-list-2.3-medium.txt (220,558 entries)
Netcat (nc)	Reverse shell listener on attacker port 443
Python3	Temporary HTTP server to transfer reverse shell payload (rev.sh) to target
base64 (native)	Decoding Base64-encoded credentials found in the server log file
GTFOBins	Reference database for identifying privilege escalation vectors via sudo-enabled binaries (tar)
Browser DevTools	Manual inspection of HTML source code and JavaScript files for information disclosure

3. Findings Summary

The following table summarizes all seven security findings identified during this engagement, ordered by severity. Three findings are rated Critical, two High, and two Medium.

Severity Level	Count	Distribution	Percentage
CRITICAL	3		43%
HIGH	2		29%
MEDIUM	2		29%
LOW	0	—	0%

ID	Finding Name	Severity	CVSS	Affected Component	Status
FINDING-01	Sensitive Information Disclosure via HTML Source Code Comments	MEDIUM	5.3	Web Application – index.html	Open – Remediation Required
FINDING-02	Unrestricted PHP File Upload Enabling Remote Code Execution (RCE)	CRITICAL	9.8	Web Application – /m4ch1n3_upload.html	Open – Remediation Required
FINDING-03	Directory Listing Enabled on the /uploads Directory	MEDIUM	5.3	Apache Web Server – /uploads	Open – Remediation Required
FINDING-04	User Credentials Stored in Base64 within a Publicly Readable Log File	HIGH	7.8	Web Server Filesystem – /var/www/html/access_log	Open – Remediation Required
FINDING-05	Shared SSH RSA Private Key Deployed Across All System Users	CRITICAL	9.0	SSH Service – /home/*.ssh/id_rsa	Open – Remediation Required
FINDING-06	SSH Key Passphrase Disclosed in Plaintext within an Internal Incident Report	HIGH	7.8	Filesystem – /home/alice/incidents/report	Open – Remediation Required
FINDING-07	Unrestricted Sudo Privileges on tar Binary Enabling Privilege Escalation to Root	CRITICAL	8.8	OS Configuration – sudo policy for user bob	Open – Remediation Required

4. Detailed Findings

FINDING-01 – Sensitive Information Disclosure via HTML Source Code Comments

Severity	MEDIUM
CVSS v3.1 Score	5.3
CVSS Vector	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
Affected Component	Web Application – index.html
Status	Open – Remediation Required
Description	An HTML comment embedded in the application's main index page disclosed two operationally significant data points to any unauthenticated user who inspected the page source: the username 'Bob' (an active system account) and the hidden URL path '/m4ch1n3_upload.html', which hosts the file upload functionality. No authentication, tools, or technical expertise was required to obtain this information.
Evidence	HTML comment identified via browser Developer Tools (Inspector): '<!-- Nota: Bob ha implementado una nueva funcionalidad en m4ch1n3_upload.html. -->'. The comment directly referenced an active system account and an unlisted application path with file upload capabilities, providing the initial attack vector for this engagement.
Remediation	Remove all HTML comments containing system usernames, internal paths, or operational notes prior to deployment. Implement a pre-deployment review checklist that explicitly covers information disclosure in source code. Conduct periodic automated scans using tools such as OWASP ZAP or Nikto to detect residual information disclosure patterns.
Likelihood	4 / 5
Impact	2 / 5

FINDING-02 – Unrestricted PHP File Upload Enabling Remote Code Execution (RCE)

Severity	CRITICAL
CVSS v3.1 Score	9.8
CVSS Vector	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Affected Component	Web Application – /m4ch1n3_upload.html
Status	Open – Remediation Required
Description	The file upload form at /m4ch1n3_upload.html explicitly listed .php as a permitted file extension. Uploaded files were stored within the web server root (/var/www/html/uploads/) and were directly accessible via HTTP. This configuration permitted any unauthenticated attacker to upload a malicious PHP script and execute arbitrary operating system commands on the server. This vulnerability is classified as Remote Code Execution (RCE) and represents the primary initial access vector in this engagement.
Evidence	A PHP web shell (shell.php) was uploaded without authentication. Execution was confirmed via: curl http://172.17.0.2/uploads/shell.php?cmd=whoami, which returned 'www-data', confirming server-side code execution. A reverse shell was subsequently established over TCP port 443, providing full interactive access as the www-data service account.
Remediation	Remove .php and all other executable extensions from the permitted upload types. Restrict uploads to .txt and .pdf only. Store uploaded files outside the web root to prevent direct HTTP access. Rename uploaded files to random, non-guessable filenames without original extensions. Validate file content type server-side using MIME inspection, not solely file extension. Deploy a Web Application Firewall (WAF) to detect and block malicious upload attempts.
Likelihood	5 / 5
Impact	5 / 5

FINDING-03 – Directory Listing Enabled on the /uploads Directory

Severity	MEDIUM
CVSS v3.1 Score	5.3
CVSS Vector	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
Affected Component	Apache Web Server – /uploads
Status	Open – Remediation Required
Description	Apache directory listing was enabled on the /uploads path, exposing the full directory contents to any unauthenticated HTTP request. This facilitated direct identification and retrieval of all uploaded files, including the malicious web shell. Directory listing also assists attackers in mapping application structure and identifying sensitive files for further exploitation.

Evidence	Navigating to <code>http://172.17.0.2/uploads/</code> returned a full Apache directory index page titled 'Index of /uploads', displaying <code>shell.php</code> with its modification date (2026-03-24 01:53) and file size (31 bytes), confirming successful upload and enabling direct access to the web shell.
Remediation	Disable directory listing globally by setting 'Options -Indexes' in the Apache server configuration. Ensure the /uploads directory serves a static index file or returns a 403 Forbidden response to direct requests. Restrict HTTP access to the uploads directory using Apache access control directives (Require all denied).
Likelihood	4 / 5
Impact	2 / 5

FINDING-04 – User Credentials Stored in Base64 within a Publicly Readable Log File

Severity	HIGH
CVSS v3.1 Score	7.8
CVSS Vector	AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N
Affected Component	Web Server Filesystem – /var/www/html/access_log
Status	Open – Remediation Required
Description	The server log file <code>access_log</code> , located in the web root and readable by the <code>www-data</code> service account, contained a Base64-encoded string that decoded directly to the credentials of system user <code>alice</code> . Base64 is an encoding scheme, not encryption, and is trivially reversible by any attacker. Storing credentials in any log file—regardless of encoding or obfuscation—is a critical security misconfiguration that directly enabled lateral movement in this engagement.
Evidence	The <code>access_log</code> contained the entry: 'Clave codificada generada: <code>YWxpY2U6czNjcjN0cEBzc3cwcmReNDg3</code> '. Decoding via <code>'echo [string] base64 -d'</code> returned <code>'alice:s3cr3tp@ssw0rd^487'</code> . These credentials were used to successfully authenticate as user <code>alice</code> via the <code>su</code> command, enabling lateral movement to a higher-privileged account.
Remediation	Remove all credentials from log files immediately. Audit all log files system-wide for similar exposures. Never store passwords in log files under any encoding, hashing, or obfuscation. Passwords must be stored exclusively as salted hashes using <code>bcrypt</code>, <code>Argon2</code>, or <code>PBKDF2</code>. Restrict read permissions on all log files to the minimum required service accounts only. Implement log sanitization to strip credential-like patterns before writing.
Likelihood	4 / 5

Impact	4 / 5
--------	-------

FINDING-05 – Shared SSH RSA Private Key Deployed Across All System Users

Severity	CRITICAL
CVSS v3.1 Score	9.0
CVSS Vector	AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:N
Affected Component	SSH Service – /home/*/.ssh/id_rsa
Status	Open – Remediation Required
Description	An automated provisioning script generated a single RSA private key (id_rsa) and deployed it identically to the .ssh directories of all system user accounts. This effectively eliminated all account isolation: any attacker who obtained the private key from any one user's directory could authenticate as any other user on the system via SSH. The affected users included alice, bob, charlie, cyberland, and ubuntu. The internal incident report discovered during this engagement explicitly documented this misconfiguration.
Evidence	Alice's incident report at /home/alice/incidents/report confirmed: 'el script generó una única clave id_rsa y la replicó en todos los directorios de usuario'. Using /home/alice/.ssh/id_rsa with the exposed passphrase, the tester authenticated successfully as bob: ssh -i .ssh/id_rsa bob@localhost. SSH session was established, confirming lateral movement via the shared key.
Remediation	Generate unique RSA or Ed25519 key pairs for every system user. No two users should share a private key under any circumstances. Revoke and replace all existing SSH keys system-wide immediately. Audit and remove automated key generation or replication scripts. Enforce periodic SSH key rotation policies. Deploy SSH authentication monitoring and alerting for anomalous login patterns.
Likelihood	4 / 5
Impact	5 / 5

FINDING-06 – SSH Key Passphrase Disclosed in Plaintext within an Internal Incident Report

Severity	HIGH
CVSS v3.1 Score	7.8

CVSS Vector	AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N
Affected Component	Filesystem – /home/alice/incidents/report
Status	Open – Remediation Required
Description	An internal incident report stored at /home/alice/incidents/report contained the passphrase for the shared SSH private key ('cyb3r_s3curity') written in plaintext. Combined with the shared RSA key vulnerability (FINDING-05), this passphrase allowed the tester to authenticate as any user on the system, including bob. The file was accessible to any process running with alice's privileges, including the previously established reverse shell session.
Evidence	The report contained the explicit statement: 'Passphrase del Usuario bob: cyb3r_s3curity'. This passphrase successfully decrypted the RSA private key when used with the ssh command, enabling authentication as bob and subsequent privilege escalation to root.
Remediation	Remove the incident report file and audit all user home directories for files containing credentials, passphrases, or secrets. Establish an organizational policy explicitly prohibiting the storage of credentials or secrets in internal documentation, reports, or notes. Adopt a secrets management solution (e.g., HashiCorp Vault) for all sensitive security information.
Likelihood	4 / 5
Impact	4 / 5

FINDING-07 – Unrestricted Sudo Privileges on tar Binary Enabling Privilege Escalation to Root

Severity	CRITICAL
CVSS v3.1 Score	8.8
CVSS Vector	AV:L/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H
Affected Component	OS Configuration – sudo policy for user bob
Status	Open – Remediation Required
Description	The sudo configuration for user bob granted unrestricted execution of /bin/tar as root without requiring a password (NOPASSWD: /bin/tar). The tar utility supports checkpoint actions (--checkpoint-action), which can execute arbitrary shell commands at runtime. When invoked as root via sudo, this mechanism spawned a root-level shell. This technique is well-documented in GTF0Bins and is a recognized privilege escalation vector in security assessments.

Evidence	'sudo -l' as bob returned: '(ALL) NOPASSWD: /bin/tar'. The GTFOBins exploit was executed: <code>sudo tar -cf /dev/null /dev/null --checkpoint=1 --checkpoint-action=exec=/bin/sh</code> , which spawned a shell. 'whoami' confirmed root-level access. The root flag at /root/root.txt was retrieved: CYBERLAND{r00t_4cc3ss_gr4nt3d}.
Remediation	Remove /bin/tar from bob's sudo permissions immediately. Audit all sudo configurations across all users and apply the principle of least privilege (PoLP). Prohibit NOPASSWD entries for any binary listed in GTFOBins or capable of spawning a shell or executing arbitrary commands. Implement sudo execution logging and alerting for all privileged command invocations.
Likelihood	3 / 5
Impact	5 / 5

5. MITRE ATT&CK Mapping

The following table maps each action taken during the assessment to the corresponding MITRE ATT&CK (v14) tactic, technique, and sub-technique. All findings map to documented adversary behaviors, demonstrating that the attack chain followed well-known, reproducible patterns.

Tactic	Tech ID	Technique	Finding	How Applied
Reconnaissance	T1595.00 1	Active Scanning: IP Blocks	Pre-engagement	Nmap SYN scan across all 65,535 TCP ports on 172.17.0.2
Reconnaissance	T1595.00 2	Active Scanning: Vulnerability Scanning	Pre-engagement	Nmap service/version detection (-sVC) on open ports 22 and 80
Discovery	T1083	File and Directory Discovery	FINDING-03	Gobuster directory enumeration with directory-list-2.3-medium.txt; discovered /uploads and /server-status
Discovery	T1087.00 1	Account Discovery: Local Account	FINDING-04/05	Read /etc/passwd; explored /home directory to enumerate local accounts (alice, bob, charlie, ubuntu, cyberland)
Discovery	T1082	System Information Discovery	Post-exploitation	Executed whoami, id, uname to identify current user context and system information
Discovery	T1548.00 3	Abuse Elevation Control: Sudo Enumeration	FINDING-07	Executed sudo -l as bob to identify sudo permissions on /bin/tar (NOPASSWD)
Initial Access	T1190	Exploit Public-Facing Application	FINDING-02	Uploaded PHP web shell (shell.php) via unrestricted file upload form at /m4ch1n3_upload.html
Execution	T1059.00 4	Unix Shell – Command Interpreter	FINDING-02	Executed system commands via PHP web shell; established interactive bash reverse shell
Persistence	T1505.00 3	Server Software Component: Web Shell	FINDING-02	shell.php persisted in /var/www/html/uploads/ enabling repeated remote command execution
Command & Control	T1071.00 1	Application Layer Protocol: Web Protocols	FINDING-02	Reverse shell established over TCP port 443 from target to attacker (10.0.2.15) using netcat

Credential Access	T1552.001	Unsecured Credentials: Credentials in Files	FINDING-04	Base64-encoded credentials for alice found in /var/www/html/access_log; decoded via native base64 utility
Credential Access	T1552.004	Unsecured Credentials: Private Keys	FINDING-05/06	Shared RSA private key in /home/alice/.ssh/id_rsa; passphrase 'cyb3r_s3curity' found in incidents/report
Credential Access	T1552.003	Unsecured Credentials: Bash History	FINDING-06	Read /home/alice/.bash_history to identify SSH key management activity and incidents directory
Lateral Movement	T1078.003	Valid Accounts: Local Accounts	FINDING-04	Used alice's decoded credentials (alice:s3cr3tp@ssw0rd^487) to pivot from www-data via su alice
Lateral Movement	T1021.004	Remote Services: SSH	FINDING-05	Authenticated as bob via SSH using shared private RSA key and exposed passphrase
Privilege Escalation	T1548.003	Abuse Elevation Control: Sudo	FINDING-07	Exploited NOPASSWD sudo on /bin/tar using GTFOBins checkpoint technique to spawn root shell

6. Risk Matrix (ISO/IEC 27005)

The risk matrix below visualizes each finding's position based on its Likelihood (1–5, horizontal axis) and Impact (1–5, vertical axis), consistent with the ISO/IEC 27005 risk assessment framework. Cell colors represent the resulting risk level. Finding identifiers are placed at their corresponding matrix positions.

Impact \ Likelihood →	1 Very Low	2 Low	3 Medium	4 High	5 Very High
5 – Critical	HIGH	HIGH	F07 CRITICAL	F05 CRITICAL	F02 CRITICAL
4 – High	MEDIUM	HIGH	HIGH	F04 / F06 CRITICAL	CRITICAL
3 – Medium	LOW	MEDIUM	HIGH	HIGH	CRITICAL
2 – Low	LOW	LOW	MEDIUM	F01 / F03 HIGH	HIGH
1 – Very Low	LOW	LOW	LOW	MEDIUM	MEDIUM

Legend: CRITICAL = immediate remediation required; HIGH = remediate within 30 days; MEDIUM = remediate within 90 days; LOW = remediate in next maintenance cycle.

7. Recommendations Summary

The following remediation recommendations are organized by priority tier based on severity and exploitability. Findings rated Critical represent active, remotely exploitable attack vectors and must be addressed as a matter of urgency.

Priority	Finding	Recommendation	Timeline
1 – CRITICAL	FINDING-02	Restrict file uploads to .txt and .pdf; move uploads outside web root; validate MIME types server-side.	Immediate (0–7 days)
2 – CRITICAL	FINDING-07	Remove NOPASSWD sudo on tar; audit all sudo rules; apply principle of least privilege.	Immediate (0–7 days)
3 – CRITICAL	FINDING-05	Generate unique SSH keys per user; revoke and replace all existing shared keys; audit provisioning scripts.	0–14 days
4 – HIGH	FINDING-04	Remove credentials from all log files; implement log sanitization; use bcrypt/Argon2 for credential storage.	0–14 days
5 – HIGH	FINDING-06	Remove incident report; audit home directories; adopt a secrets management solution.	0–14 days
6 – MEDIUM	FINDING-03	Disable Apache directory listing (Options -Indexes); restrict HTTP access to /uploads.	7–30 days
7 – MEDIUM	FINDING-01	Remove all HTML comments with operational data; implement pre-deployment review checklist.	7–30 days

In addition to the remediation of individual findings, the following general hardening measures are recommended:

7.1 Web Server Hardening

- Disable directory listing globally (Options -Indexes in Apache configuration).
- Keep Apache up to date with security patches.
- Deploy a Web Application Firewall (WAF) for the exposed web application.
- Restrict file permissions on all web server directories to the minimum required.

7.2 Operating System Hardening

- Apply security updates on a regular, documented schedule.
- Disable unused ports and services.
- Periodically audit SUID binaries and remove unnecessary elevated permissions.
- Disable SSH password authentication and enforce key-based authentication only.

7.3 SOC / Monitoring Considerations

A Security Operations Center (SOC) with an active SIEM would have been capable of detecting several stages of this attack chain. The following monitoring rules are recommended:

- Alert on file uploads with executable extensions (.php, .sh, .py) to the web server.
- Monitor outbound network connections originating from the www-data account.
- Alert on sudo invocations for high-risk binaries (tar, python, find, bash).
- Centralize and correlate Apache and SSH logs via a SIEM solution (e.g., Wazuh, Splunk).

8. Appendices

Appendix A – Engagement Environment

Attacker Machine: Kali Linux 2025.4 (VirtualBox VM, Debian 64-bit, 4 GB RAM) — IP: 10.0.2.15

Target Machine: Forgotten Portal Docker container — IP: 172.17.0.2

Deployment command: `sudo bash auto_deploy.sh forgotten_portal.tar`

Appendix B – Acronyms

Acronym	Definition
CIA	Confidentiality, Integrity, Availability
CVSS	Common Vulnerability Scoring System
MITRE ATT&CK	Adversarial Tactics, Techniques and Common Knowledge
NOPASSWD	Sudo directive allowing passwordless execution
PTES	Penetration Testing Execution Standard
RCE	Remote Code Execution
SIEM	Security Information and Event Management
SOC	Security Operations Center
SUID	Set User ID (file permission bit)
TTL	Time to Live (network packet field)
WAF	Web Application Firewall

Appendix C – Disclaimer

All activities documented in this report were conducted exclusively within the controlled DockerLabs lab environment described in Section 2.1. No real systems, production infrastructure, or third-party services were affected. This report was produced for educational and portfolio purposes as part of the Nodo EAFIT Cybersecurity Accelerator program.